

Lab 08: Threat Modeling

Cybersecurity F26

March 25th, 2026

Sani Abdullahi

1. Introduction

In this lab, you will perform threat modeling to systematically identify and analyze potential security risks in a given system. Threat modeling is a fundamental technique used to guide security considerations throughout the system lifecycle, from initial planning and design to development and deployment.

The process involves examining a system to uncover possible threats, typically by creating and analyzing representations such as data flow diagrams (DFDs), which illustrate system components, data flows, and trust boundaries. Based on this analysis, potential attack vectors are mapped to specific parts of the system, enabling the identification of appropriate mitigations.

Threat modeling shares similarities with threat assessment activities conducted during penetration testing. However, unlike penetration testers who must infer system details through active and passive reconnaissance, threat modeling is performed with full system knowledge, allowing for a more structured and comprehensive evaluation of security risks.

Submission and Exam Relevance

This is one of six lab exercises that you are required to submit via itslearning. The submission serves as an important supporting material during the final written exam. As the focus of this exercise is on the creation of diagrams and tables rather than extensive written explanations, a free-form PDF document is the preferred format for submission.

Exercises: Threat Modeling

In these exercises, you are expected to include data flow diagrams as well as structured lists or tables of identified threats. Aim to provide multiple examples for each relevant threat category.

Pre-Exercise Preparation:

Read the Acme case study available in the “Resources” folder under the “Lab” section of this lecture in itslearning. In the same folder, you will also find the EoP card game materials, which you should review. Download both documents and ensure they are accessible during the exercise session.

Exercise 1: Creating a Simple Data Flow Diagram**Tasks**

1. Working in your respective groups, develop a data flow diagram (DFD) for the following system:
 - An Android-based health application
 - User authentication via username and password
 - Functionality to manually enter, edit, and delete personal data (e.g., height, weight, activity, and diet).
 - Data storage performed locally on the device

Use the Microsoft Threat Modeling Tool to create your diagram. However, feel free to also use any other tool of your choice (e.g., draw.io, Inkscape, or even pen and paper).

NOTE: You can make reasonable assumptions where necessary (e.g., mobile platform specifics, native framework, system components), but ensure these assumptions are clearly reflected in your diagram.

Exercise 2: Applying the STRIDE Model**Tasks**

1. For the Android health application defined in Exercise 1, apply the STRIDE framework to identify and categorize potential threats:
 - Spoofing
 - Tampering
 - Repudiation
 - Information Disclosure
 - Denial of Service
 - Elevation of Privilege (EoP)
2. For each category, identify and describe relevant threats to the system. Where possible, provide multiple examples per category.

3. Use the Acme case study and the provided card game materials as guidance. You may also consult external resources for inspiration and reference, such as:
 - OWASP resources
 - CAPEC (Common Attack Pattern Enumeration and Classification)
 - CVE (Common Vulnerabilities and Exposures)
 - Exploit-DB
 - CMU materials

Exercise 3: Discussion of Data Flow Diagram and STRIDE Analysis

Tasks

1. Discuss your results from Exercises 1 and 2, ideally with another group. Use this discussion to refine and complete both your DFD and your STRIDE analysis.
2. Include your final data flow diagram along with a brief description of its key components. Additionally, provide a structured list or table summarizing your identified threats according to the STRIDE categories.

Exercise 4: Updating the Data Flow Diagram and STRIDE Analysis

Tasks

1. Extend your DFD and STRIDE analysis to reflect a modified version of the application, where it evolves into a fitness tracker.
Consider the following changes:
 - The app collects data from third-party devices (e.g., via Bluetooth)
 - Data includes fitness-related metrics such as steps taken, distance traveled, calories burned, activity levels, and sleep patterns.
 - The app processes and cleans the collected data and performs necessary computations.
 - Users can no longer modify the data manually
 - Data is stored both locally on the device and in a cloud service.
2. Update your DFD to reflect the new components, data flows, and trust boundaries.
3. Then revise your STRIDE analysis accordingly to account for new threats introduced by external devices, wireless communication, and cloud storage.

Exercise 5: Discussion of Updated Data Flow Diagram and STRIDE Analysis**Tasks**

1. Discuss your results from Exercise 4, ideally with another group. Use this discussion to refine and complete your updated DFD and STRIDE analysis.
2. Include your updated DFD along with a brief description of its key components. Additionally, provide a structured list or table summarizing your identified threats according to the STRIDE categories.

NOTE: While the application requirements are defined at a high level, no specific implementation details are provided. This is intentional, allowing students to choose a development environment they are most comfortable with. For example, a Java application, a native backend, or a web framework that supports deployment to platforms such as Android.

The purpose of this exercise is to encourage a practical threat modeling approach that enables students to focus on identifying potential security issues rather than on specific implementation choices.

HINT: Clearly define assumptions, focus on trust boundaries, apply STRIDE, keep diagrams and tables structured, and update your analysis as the system evolves
